RANSOMWARE-CREDENTIAL-THREATS

랜섬웨어·RaaS·인포스틸러·계정 공격

연관 기출 · 128-1-12, 138-4-5, 129-4-1, 131-1-10, 132-1-6

한눈에 이해

파일 암호화 뒤의 복구 문제와 그 전에 빼앗긴 계정·세션·자료 유출을 함께 다룹니다.

정의와 핵심 원리

랜섬웨어는 암호화·데이터 탈취·공개 위협 등으로 피해자를 갈취하는 악성 행위입니다. RaaS는 운영자·제휴 공격자 등이 도구·인프라·수익 분배로 역할을 나누는 서비스형 범죄 모델이며 별도 암호 알고리즘이 아닙니다.

• 공격의 진입 경로는 피싱·외부에 노출된 원격 접속 서비스·취약점·공급망·도난 자격 증명 등입니다. 공격은 정찰·권한 상승·측면 이동·정보 탈취·백업 훼손·암호화로 이어질 수 있지만 순서는 사례마다 다릅니다. 대용량 파일은 대칭 암호로 암호화하고 키를 공개 키로 보호하는 등 하이브리드 구조가 가능합니다.

• 인포스틸러는 브라우저 비밀번호·쿠키·토큰·지갑 등을 탈취합니다. 공격자는 탈취한 세션 토큰으로 다중 인증(MFA)을 마친 세션을 악용할 수 있습니다. 크리덴셜 스터핑은 다른 서비스에서 유출된 아이디와 암호 조합을 재사용하는 공격입니다. 가능한 암호를 차례로 시도하는 무차별 대입과 구분합니다. 큐싱은 QR 코드로 악성 사이트·피싱을 유도하는 사회 공학입니다.

• 예방하려면 보안 패치를 적용하고 피싱에 강한 인증을 도입합니다. 계정 권한과 원격 접속 노출을 줄이고, 네트워크를 분리하고 이상 징후를 탐지합니다. 오프라인 또는 불변 백업의 복원도 시험합니다. 사고가 나면 영향을 받은 시스템을 격리하고 증거를 보존해 피해 범위를 파악합니다. 자격 증명과 세션을 회수하고 신고·통지 여부를 검토합니다. 침해 전 백업으로 복구하고 원인을 제거한 뒤 재발 위험을 점검합니다. 복구 중에는 업무 연속성과 유출 대응도 함께 관리합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
랜섬웨어	암호화·탈취·갈취	복원·유출·업무 영향
RaaS	도구·인프라·제휴 분업	공격 규모·역할 분리
인포스틸러/스터핑	비밀 정보 탈취 / 유출된 자격 증명 재사용	세션 회수·중복 암호 대응

적용 예제

백업이 있어도 필요한 대응

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 파일 암호화와 관리자 쿠키 탈취의 징후가 함께 보입니다.

1. 네트워크·계정 접근을 격리하고 증거를 보존합니다.
2. 암호화 범위와 탈취·백업 훼손을 따로 조사합니다.
3. 암호를 변경하고 기존 세션과 토큰을 회수합니다.
4. 침해 전 백업으로 복구한 뒤 침입 원인을 제거했는지, 새 접근 흔적이 있는지 확인합니다.

결과·해석: 백업 복원 완료를 사고 전체 종결과 동일시하지 않습니다.

전제·주의: CISA 가이드에 접근할 때 403 오류가 발생했습니다. 일반 대응 원칙은 NIST 포렌식 문서와 MITRE 자료를 바탕으로 설명했습니다.

답안 골격과 혼동 방지

위협·분업 → 침입과 확산 → 키·데이터 갈취 → 예방·대응 흐름 → 복구 검증

- RaaS는 공격 도구와 운영을 나눠 제공하는 범죄 모델입니다.
- MFA를 사용해도 이미 인증된 세션의 쿠키가 탈취될 수 있습니다.

내용을 가리고 회상

1. 랜섬웨어와 RaaS의 비교 축은 무엇입니까?
2. 비밀번호 변경만으로 세션 탈취가 끝납니까?
3. 불변 백업에도 복원 시험이 필요한 이유는 무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- MITRE ATT&CK TA0008 Lateral Movement - MITRE; 최종수정 2025-08-11; 확인 2026-11-05.
- NIST SP800-86 Integrating Forensics into Incident Response - Karen Kent et al. / NIST; 2006-08; 확인 2026-11-05.
- NIST SP800-63B-4 Authentication - NIST; 2025-07; 확인 2026-11-05.